

Data Security Policy

Section 1: Password Requirements

All employee passwords must be a minimum of 14 characters and include at least one uppercase letter, one number, and one symbol. Passwords must be rotated every 90 days for accounts with access to client data, and every 180 days for all other accounts. Multi-factor authentication (MFA) is mandatory for all accounts accessing the client data platform, with no exceptions, including for administrator accounts.

Section 2: Data Classification

Data is classified into three tiers. Tier 1 (Public) may be shared externally without restriction. Tier 2 (Internal) may be shared within the company but requires manager approval to share externally. Tier 3 (Restricted) includes client records and personal health information, and may only be accessed by employees with an active data access agreement on file with Legal, renewed every 12 months.

Section 3: Incident Response

Any suspected data breach or unauthorized access must be reported to the Security team within 1 hour of discovery via the incident hotline, not by email. The Security team is required to notify affected clients within 72 hours of confirming a breach involving Tier 3 data, in line with contractual and regulatory obligations.

Section 4: Device Security

Company-issued laptops must have full-disk encryption enabled and connect to company systems only through the approved VPN client. Personal devices are not permitted to access Tier 3 data under any circumstances, including personal phones checking work email.